Este sitio web utiliza tecnologías como cookies para habilitar la funcionalidad esencial del sitio, así como para analítica, personalización y publicidad dirigida. Para obtener más información, consulte el siguiente enlace: Política de privacidad

Administrar preferencias

Brute Force: Password Spraying

Other sub-techniques of Brute Force (4)

Adversaries may use a single or small list of commonly used passwords against many different accounts to attempt to acquire valid account credentials. Password spraying uses one password (e.g. 'Password01'), or a small list of commonly used passwords, that may match the complexity policy of the domain. Logins are attempted with that password against many different accounts on a network to avoid account lockouts that would normally occur when brute forcing a single account with many passwords.[1]

Typically, management services over commonly used ports are used when password spraying. Commonly targeted services include the following:

- SSH (22/TCP)
- Telnet (23/TCP)
- FTP (21/TCP)
- NetBIOS / SMB / Samba (139/TCP & 445/TCP)
- LDAP (389/TCP)
- Kerberos (88/TCP)
- RDP / Terminal Services (3389/TCP)
- HTTP/HTTP Management Services (80/TCP & 443/TCP)
- MSSQL (1433/TCP)
- Oracle (1521/TCP)
- MySQL (3306/TCP)
- VNC (5900/TCP)

In addition to management services, adversaries may "target single sign-on (SSO) and cloud-based applications utilizing federated authentication protocols," as well as externally facing email applications, such as Office 365.[2]

In order to avoid detection thresholds, adversaries may deliberately throttle password spraying attempts to avoid triggering security alerting. Additionally, adversaries may leverage LDAP and Kerberos authentication attempts, which are less likely to trigger high-visibility events such as Windows "logon failure" event ID 4625 that is commonly triggered by failed SMB connection attempts.[3]

ID: T1110.003

Sub-technique of: T1110

Tactic: Credential Access

Platforms: Containers, ESXi, IaaS, Identity Provider, Linux, Network Devices, Office Suite, SaaS, Windows, macOS

Contributors: John Strand; Microsoft Threat Intelligence Center (MSTIC)

Version: 1.8

Created: 11 February 2020

Last Modified: 04 November 2026

Version Permalink

Este sitio web utiliza tecnologías como cookies para habilitar la funcionalidad esencial del sitio, así como para analítica, personalización y publicidad dirigida. Para obtener más información, consulte el siguiente enlace: Política de privacidad

Procedure Examples

ID	Name	Description
G1030	Agrius	Agrius engaged in password spraying via SMB in victim environments.[4]
C0064	AI-Assisted Breach of Mexico's Government Infrastructure	During the AI-Assisted Breach of Mexico's Government Infrastructure, the adversary tasked Claude Code to attempt to password spray several database servers.[5] During the AI-Assisted Breach of Mexico's Government Infrastructure, the adversary has also instructed Claude Code to attempt to password spray a SCADA web interface.[5]
G0007	APT28	APT28 has used a brute-force/password-spray tooling that operated in two modes: in password-spraying mode it conducted approximately four authentication attempts per hour per targeted account over the course of several days or weeks.[6][7] APT28 has also used a Kubernetes cluster to conduct distributed, large-scale password spray attacks.[8]
C0051	APT28 Nearest Neighbor Campaign	During APT28 Nearest Neighbor Campaign, APT28 performed password-spray attacks against public facing services to validate credentials.[9]
G0016	APT29	APT29 has conducted brute force password spray attacks.[10][11][12]
G0064	APT33	APT33 has used password spraying to gain access to target systems.[13][14]
S0606	Bad Rabbit	Bad Rabbit's `infpub.dat` file uses NTLM login credentials to brute force Windows machines.[15]
G0114	Chimera	Chimera has used multiple password spraying attacks against victim's remote services to obtain valid user and administrator accounts.[16]
S0488	CrackMapExec	CrackMapExec can brute force credential authentication by using a supplied list of usernames and a single password.[17]
G1003	Ember Bear	Ember Bear has conducted password spraying against Outlook Web Access (OWA) infrastructure to identify valid user names and passwords.[18]
G0125	HAFNIUM	HAFNIUM has gained initial access through password spray attacks.[19]
G1001	HEXANE	HEXANE has used password spraying attacks to obtain valid credentials.[20]
G0032	Lazarus Group	Lazarus Group malware attempts to connect to Windows shares for lateral movement by using a generated list of usernames, which center around permutations of the username Administrator, and weak passwords.[21][22]
G0077	Leafminer	Leafminer used a tool called Total SMB BruteForcer to perform internal password spraying.[23]
S0362	Linux Rabbit	Linux Rabbit brute forces SSH passwords in order to attempt to gain access and install its malware onto the server. [24]
S0413	MailSniper	MailSniper can be used for password spraying against Exchange and Office 365.[25]
G1059	NIMBUS MANTICORE	NIMBUS MANTICORE has conducted password spraying attacks against victim environments.[26]
C0055	Quad7 Activity	Quad7 Activity has conducted a throttled variant of password spraying techniques that only utilized a single attempt to sign in within a 24-hour time period, eluding brute force detection thresholds.[3]

Este sitio web utiliza tecnologías como cookies para habilitar la funcionalidad esencial del sitio, así como para analítica, personalización y publicidad dirigida. Para obtener más información, consulte el siguiente enlace: Política de privacidad

Mitigations

ID	Mitigation	Description
M1036	Account Use Policies	Set account lockout policies after a certain number of failed login attempts to prevent passwords from being guessed. Too strict a policy may create a denial of service condition and render environments un-usable, with all accounts used in the brute force being locked-out. Use conditional access policies to block logins from non-compliant devices or from outside defined organization IP ranges.[28] Consider blocking risky authentication requests, such as those originating from anonymizing services/proxies.[29]
M1032	Multi-factor Authentication	Use multi-factor authentication. Where possible, also enable multi-factor authentication on externally facing services.
M1027	Password Policies	Refer to NIST guidelines when creating password policies. [30]

Detection Strategy

ID	Name	Analytic ID	Analytic Description
DET0487	Distributed Password Spraying via Authentication Failures Across Multiple Accounts	AN1336	A high volume of authentication failures using a single password (or small set) across many different user accounts within a defined time window
		AN1337	Authentication failures across different accounts using a repeated or similar password via SSH or PAM stack within a short window
		AN1338	Multiple failed login attempts across different users using common password patterns (e.g., 'Welcome2023')
		AN1339	Sign-in failures across enterprise SSO applications or SaaS platforms from same IP address using the same password against multiple user identities
		AN1340	Authentication failure logs on routers/switches showing repeated use of default or common passwords across multiple accounts
		AN1341	Repeated failed authentication attempts to container APIs, control planes, or login shells across many user names using same password
		AN1342	Failed authentication attempts across user mailboxes using identical or common passwords (e.g., OWA brute attempts)
		AN1343	SaaS applications receiving authentication failures for dozens of accounts using same password or login signature

Este sitio web utiliza tecnologías como cookies para habilitar la funcionalidad esencial del sitio, así como para analítica, personalización y publicidad dirigida. Para obtener más información, consulte el siguiente enlace: Política de privacidad

References

1. Thyer, J. (2015, October 30). Password Spraying & Other Fun with RPCCLIENT. Retrieved April 25, 2017.
2. US-CERT. (2018, March 27). TA18-068A Brute Force Attacks Conducted by Cyber Actors. Retrieved October 2, 2019.
3. Microsoft Threat Intelligence. (2024, October 31). Chinese threat actor Storm-0940 uses credentials from password spray attacks from a covert network. Retrieved June 4, 2025.
4. Or Chechik, Tom Fakterman, Daniel Frank & Assaf Dahan. (2023, November 6). Agonizing Serpens (Aka Agrius) Targeting the Israeli Higher Education and Tech Sectors. Retrieved May 22, 2024.
5. Eyal Sela. (2026, April). The AI-Assisted Breach of Mexico's Government Infrastructure. Retrieved September 2, 2026.
6. Microsoft Threat Intelligence Center (MSTIC). (2020, September 10). STRONTIUM: Detecting new patterns in credential harvesting. Retrieved September 11, 2020.
7. Burt, T. (2020, September 10). New cyberattacks targeting U.S. elections. Retrieved March 24, 2021.
8. NSA, CISA, FBI, NCSC. (2021, July). Russian GRU Conducting Global Brute Force Campaign to Compromise Enterprise and Cloud Environments. Retrieved July 26, 2021.
9. Koessel, Sean. Adair, Steven. Lancaster, Tom. (2024, November 22). The Nearest Neighbor Attack: How A Russian APT Weaponized Nearby Wi-Fi Networks for Covert Access. Retrieved February 25, 2025.
10. MSRC. (2021, June 25). New Nobelium activity. Retrieved August 4, 2021.
11. Microsoft Threat Intelligence Center. (2021, October 25). NOBELIUM targeting delegated administrative privileges to facilitate broader attacks. Retrieved March 25, 2022.
12. UK National Cyber Security Center et al. (2024, February). SVR cyber actors adapt tactics for initial cloud access. Retrieved March 1, 2024.
13. Ackerman, G., et al. (2018, December 21). OVERRULED: Containing a Potentially Destructive Adversary. Retrieved January 17, 2019.
14. Microsoft Threat Protection Intelligence Team. (2020, June 18). Inside Microsoft Threat Protection: Mapping attack chains from cloud to endpoint. Retrieved June 22, 2020.
15. Mamedov, O. Sinitsyn, F. Ivanov, A.. (2017, October 24). Bad Rabbit ransomware. Retrieved January 28, 2021.
16. Jansen, W . (2021, January 12). Abusing cloud services to fly under the radar. Retrieved September 12, 2024.
17. byt3bl33d3r. (2018, September 8). SMB: Command Reference. Retrieved July 17, 2020.
18. US Cybersecurity & Infrastructure Security Agency et al. (2024, September 5). Russian Military Cyber Actors Target U.S. and Global Critical Infrastructure. Retrieved September 6, 2024.
19. Microsoft Threat Intelligence . (2025, March 5). Silk Typhoon targeting IT supply chain. Retrieved March 20, 2025.
20. SecureWorks 2019, August 27 LYCEUM Takes Center Stage in Middle East Campaign Retrieved. 2019/11/19
21. Novetta Threat Research Group. (2016, February 24). Operation Blockbuster: Unraveling the Long Thread of the Sony Attack. Retrieved February 25, 2016.
22. Novetta Threat Research Group. (2016, February 24). Operation Blockbuster: Remote Administration Tools & Content Staging Malware Report. Retrieved March 16, 2016.
23. Symantec Security Response. (2018, July 25). Leafminer: New Espionage Campaigns Targeting Middle Eastern Regions. Retrieved August 28, 2018.
24. Anomali Labs. (2018, December 6). Pulling Linux Rabbit/Rabbot Malware Out of a Hat. Retrieved March 4, 2019.
25. Bullock, B., . (2018, November 20). MailSniper. Retrieved October 4, 2019.
26. El-Banna, M., et al. (2025, November 17). Frontline Intelligence: Analysis of UNC1549 TTPs, Custom Tools, and Malware Targeting the Aerospace and Defense Ecosystem. Retrieved September 28, 2026.
27. DOJ. (2018, March 23). U.S. v. Rafatnejad et al . Retrieved February 3, 2021.
28. Microsoft. (2022, December 14). Conditional Access templates. Retrieved February 21, 2023.
29. Moussa Diallo and Brett Winterford. (2024, April 26). How to Block Anonymizing Services using Okta. Retrieved May 28, 2024.
30. Temoshok, D., et al. (July 2025). SP 800-63-4, Digital Identity Guidelines. Retrieved July 29, 2026.

Este sitio web utiliza tecnologías como cookies para habilitar la funcionalidad esencial del sitio, así como para analítica, personalización y publicidad dirigida. Para obtener más información, consulte el siguiente enlace: Política de privacidad